

Web Application Penetration Test Report

Football Hub — Django Web Application

Target	http://18.170.42.8 (EC2 instance: football-hub-test)
Attacking host	pen-test (Kali Linux, AWS EC2)
Assessment type	Authorised black-box web application penetration test
Date	August 2026
Prepared by	Babila Lewis

Independent, self-directed security assessment of a personal Django project, performed with full owner authorisation on infrastructure I control.

1. Executive Summary

This report documents an authorised penetration test carried out against the Football Hub Django application, deployed on a dedicated AWS EC2 instance (football-hub-test, public IP 18.170.42.8). The assessment was conducted from a separate, purpose-built Kali Linux EC2 instance (pen-test) and followed a standard penetration testing lifecycle: reconnaissance, scanning and enumeration, vulnerability analysis, exploitation/verification, and remediation.

The overall security posture of the application at the time of testing was good. No Critical or High severity vulnerabilities were identified. One Medium severity finding was identified — an outdated nginx reverse proxy version affected by CVE-2026-1642 (SSL Upstream Injection) — and this was remediated and independently re-verified during the engagement. A small number of Low and informational findings were also identified, primarily relating to missing security headers, the absence of HTTPS, and minor information disclosure via default files (robots.txt, sitemap.xml).

A summary of all findings, their severity, and remediation status is provided in Section 8.

2. Scope

- **In-scope target:** football-hub-test EC2 instance (18.170.42.8), running the Football Hub Django application behind an nginx reverse proxy, deployed via Docker Compose (nginx, Django/Gunicorn app, PostgreSQL, Redis).
- Testing was performed from a dedicated attacking host (pen-test EC2 instance, Kali Linux) under the same AWS account, with full authorisation as the account and application owner.
- Testing was limited to the football-hub-test instance and its exposed services; no other AWS infrastructure was in scope.
- Both unauthenticated external testing and local host-level review (following legitimate SSH / Instance Connect access) were performed.

3. Methodology

The assessment followed a standard penetration testing cycle:

- **Phase 1 — Reconnaissance:** passive and active information gathering (Nmap, SpiderFoot OSINT).

- **Phase 2 — Scanning & Enumeration:** directory/endpoint discovery and web server misconfiguration checks (Gobuster, Nikto).
- **Phase 3 — Vulnerability Analysis:** tooling scan for known CVEs and misconfigurations (Tenable Nessus Essentials).
- **Phase 4 — Exploitation & Verification:** confirmation of findings and post-remediation re-testing (Metasploit Framework).
- **Phase 5 — Remediation:** fixes applied directly to the affected service, followed by independent re-verification.

Tools & Techniques Used

Category	Tools
Reconnaissance	Nmap, SpiderFoot (OSINT)
Enumeration	Gobuster, Nikto
Vulnerability scanning	Tenable Nessus Essentials
Exploitation / verification	Metasploit Framework
Infrastructure	AWS EC2, Docker Compose, nginx, Django/Gunicorn, PostgreSQL, Redis
Remediation & re-testing	Docker image version pinning, Nessus / Metasploit re-scan

4. Phase 1: Reconnaissance

An initial Nmap scan confirmed the host was reachable and identified the exposed attack surface: port 80 (HTTP) open, and port 443 (HTTPS) closed — confirming the application was served exclusively over unencrypted HTTP.

```

PS C:\Users\User> cd .\Desktop\
PS C:\Users\User\Desktop> ssh -i ".\linux-test.pem" kali@18.175.185.103
Linux kali 6.18.12+kali-cloud-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Mon Aug 24 15:01:54 2026 from 5.81.111.173
~(Message from Kali developers)

This is a cloud installation of Kali Linux. Learn more about
the specificities of the various cloud images:
@ https://www.kali.org/docs/troubleshooting/common-cloud-setup/

~(Run: "touch ~/.hushlogin" to hide this message)
~(kali@ kali)-[~]
~$ nmap -Ph 18.170.42.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-24 16:08 +0000
Nmap scan report for ec2-18-170-42-8.eu-west-2.compute.amazonaws.com (18.170.42.8)
Host is up (0.00045s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp    closed https
Nmap done: 1 IP address (1 host up) scanned in 6.41 seconds

```

Figure 1 — Initial Nmap scan of 18.170.42.8: port 80 open, port 443 closed.

A follow-up service/version detection scan fingerprinted the web server as nginx 1.27.5. This version was later confirmed via Nessus (Section 6) to be affected by a known Medium-severity CVE. SSH (port 22) was filtered from the tester's vantage point at the time of this scan, consistent with security group rules restricting SSH access.

```

~(kali@ kali)-[~]
~$ nmap -sV -p 22,80,443 18.170.42.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-24 16:19 +0000
Nmap scan report for ec2-18-170-42-8.eu-west-2.compute.amazonaws.com (18.170.42.8)
Host is up (0.00039s latency).

PORT      STATE SERVICE VERSION
22/tcp    filtered ssh
80/tcp    open  http   nginx 1.27.5
443/tcp    closed https
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.59 seconds

```

Figure 2 — Nmap service/version scan identifying nginx/1.27.5.

Nmap's default HTTP vulnerability scripts (DOM-based XSS, stored XSS, CSRF) were also run and did not identify any issues at this stage — a useful baseline, though not a substitute for deeper testing.

```

~(kali@ kali)-[~]
~$ nmap --script vuln 18.170.42.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-24 17:53 +0000
Nmap scan report for ec2-18-170-42-8.eu-west-2.compute.amazonaws.com (18.170.42.8)
Host is up (0.00067s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
443/tcp    closed https
Nmap done: 1 IP address (1 host up) scanned in 83.30 seconds

```

Figure 3 — Nmap vulnerability script scan: no DOM-based XSS, stored XSS, or CSRF issues detected.

SpiderFoot was used to perform automated OSINT reconnaissance against the target IP, covering DNS, netblock, BGP/ASN membership, and open port data. No high, medium, or low severity correlations were flagged by SpiderFoot's built-in rules during this scan.

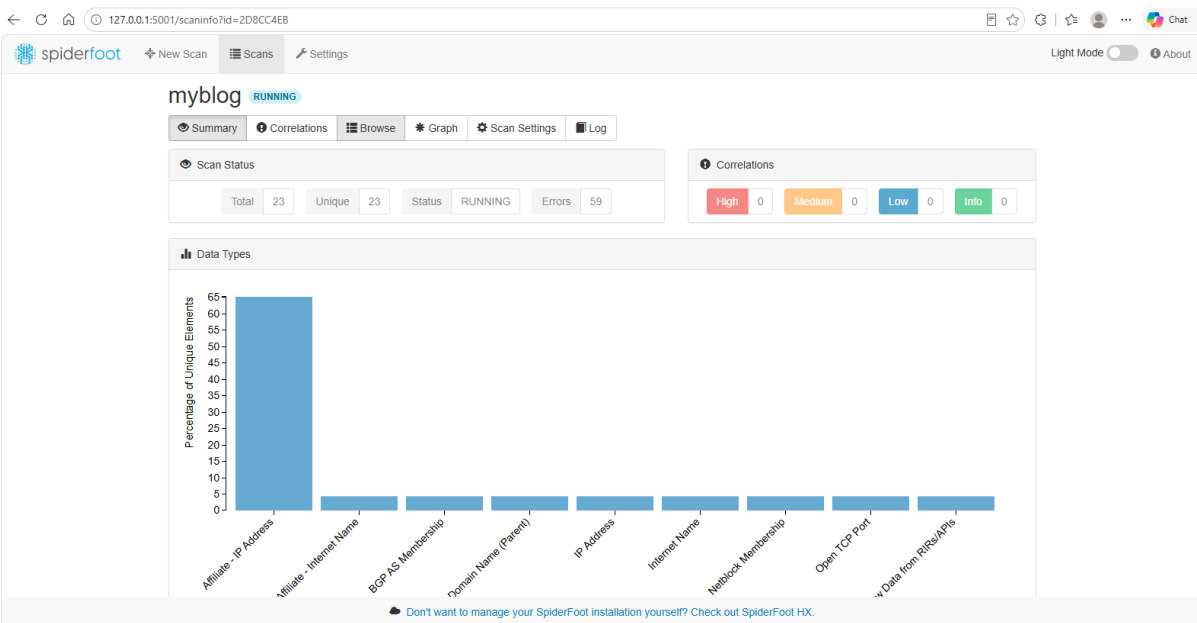


Figure 4 — SpiderFoot OSINT scan summary.

5. Phase 2: Scanning & Enumeration

Gobuster was used to enumerate hidden or undocumented directories and endpoints on the target. This surfaced the application's structure, including administrative and user-facing routes such as /admin/, /dashboard/, /login/, /logout/, /search/, /saved/, /ws/, /privacy-policy/, /careers/, /contact-us/, /feedback/, and a readable /sitemap.xml. No unexpected or clearly sensitive paths (e.g. exposed backup files, .git, or debug endpoints) were discovered.

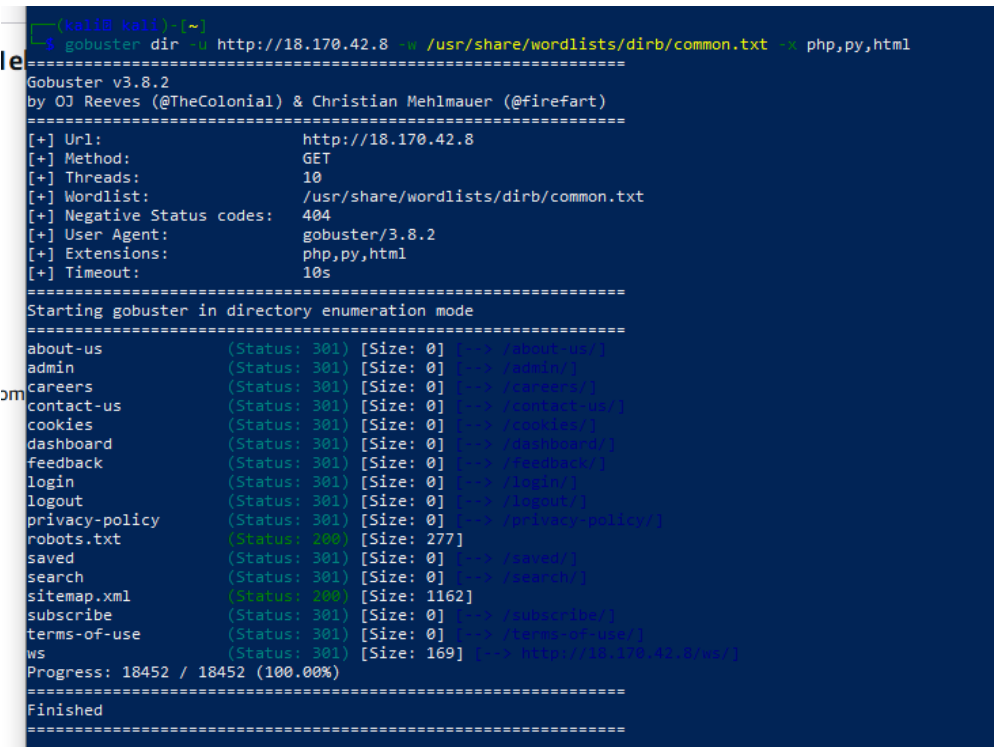


Figure 5 — Gobuster directory enumeration results.

Nikto was run against the web server to check for common misconfigurations. It confirmed the nginx/1.27.5 banner and flagged several missing recommended security headers — Content-Security-Policy, Strict-Transport-Security, Permissions-Policy, and X-Content-Type-Options — along with the presence and readability of robots.txt and sitemap.xml. None of these were classified as high risk on their own, but they represent hardening opportunities.

```
(kali@kali)~$ nikto -h http://18.170.42.8
Nikto v2.6.0

-----
+ Target IP:      18.170.42.8
+ Target Hostname: 18.170.42.8
+ Target Port:    80
+ Platform:      Unknown
+ Start Time:     2026-08-24 16:32:10 (GMT0)
-----
+ Server: nginx/1.27.5
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999997] /robots.txt: Entry '/logout/' is returned a non-forbidden or redirect HTTP code (405). See: https://www.wigger.net/kb/issues/00600600_robots-txt-file
+ [999997] /robots.txt: Entry '/csp-report/' is returned a non-forbidden or redirect HTTP code (405). See: https://www.wigger.net/kb/issues/00600600_robots-txt-file
+ [999996] /robots.txt: contains 11 entries which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [001218] /sitemap.xml: The sitemap.xml file provides a listing of the site content.
+ [001736] /login/: This might be interesting.
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ 8248 requests: 16 errors and 9 items reported on the remote host
+ End Time:      2026-08-24 16:38:27 (GMT0) (377 seconds)
-----
+ 1 host(s) tested
```

Figure 6 — Nikto web server scan results.

6. Phase 3: Vulnerability Analysis

A full Tenable Nessus Essentials “Basic Network Scan” was run against the target (unauthenticated service scan). The scan completed in 10 minutes and identified 15 total findings against the single host: 1 Medium, 1 Low, and 13 Informational. No Critical or High severity findings were identified.

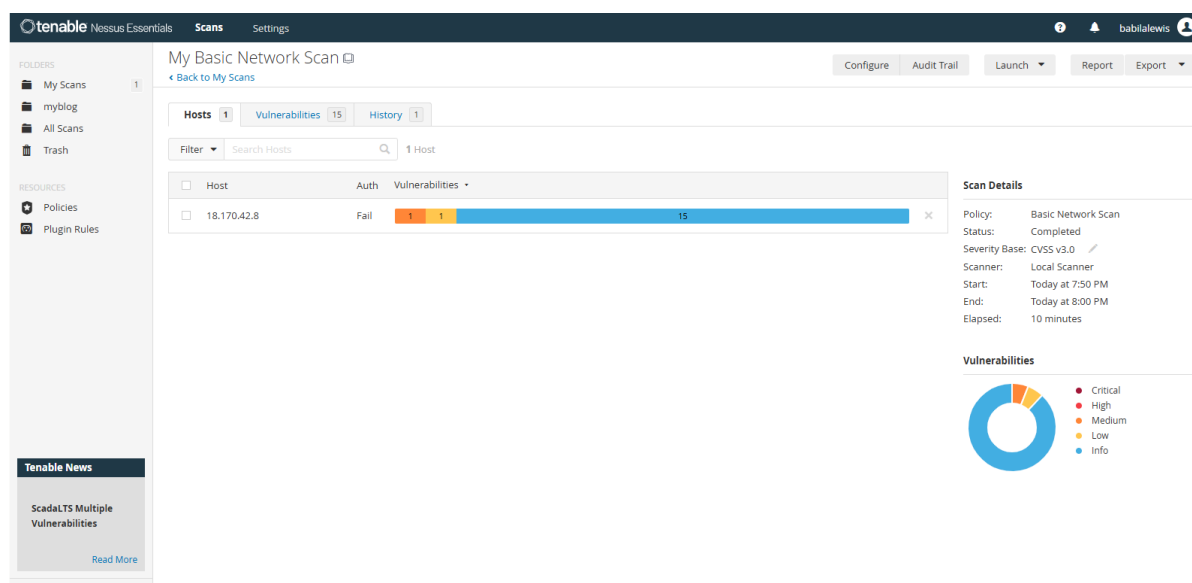


Figure 7 — Nessus Basic Network Scan summary: 0 Critical, 0 High, 1 Medium, 1 Low, 13 Info.

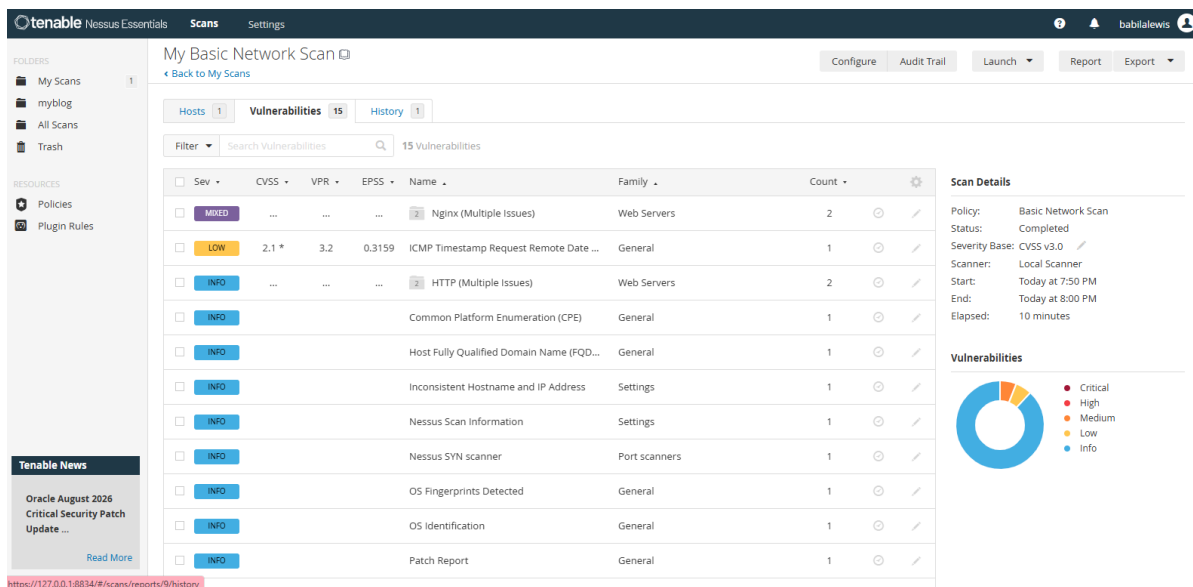


Figure 8 — Full list of the 15 findings, by severity and plugin family.

The single Medium severity finding was an outdated nginx version (1.27.5) affected by CVE-2026-1642 — an SSL Upstream Injection vulnerability affecting nginx versions 1.3.0 up to (but not including) 1.28.2, and 1.29.x prior to 1.29.5. The issue arises when nginx is configured to proxy to upstream TLS servers: an attacker with a man-in-the-middle position on the upstream side could, under certain conditions, inject plaintext data into the proxied response. Exploitation requires an existing MITM position and is not directly exploitable by a remote, unauthenticated attacker without that foothold. Nessus recommended upgrading to nginx 1.28.2 or 1.29.5 or later.

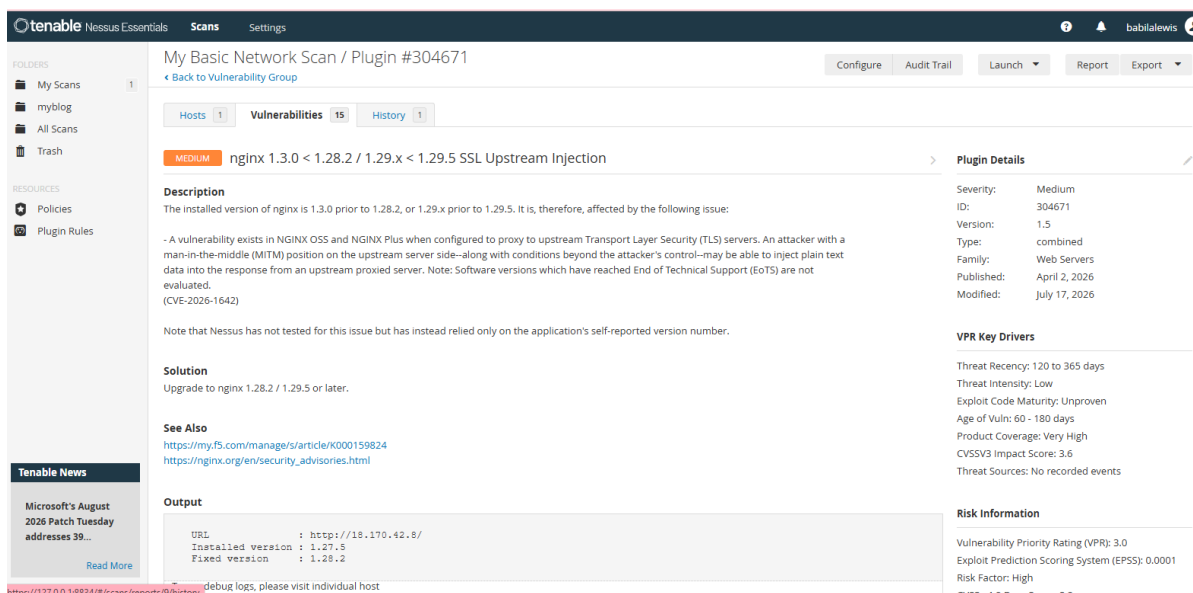


Figure 9 — CVE-2026-1642 (nginx SSL Upstream Injection) detail, as reported by Nessus.

Hosts 1	Vulnerabilities 15	History 1
---------	--------------------	-----------

Search Vulnerabilities	2 Vulnerabilities
------------------------	-------------------

☐ Sev	CVSS	VPR	EPSS	Name	Family	Count	
☐ MEDIUM	5.9	3.0	0.0001	nginx 1.3.0 < 1.28.2 / 1.29.x < 1.29.5 SSL Up...	Web Servers	1	
☐ INFO				nginx HTTP Server Detection	Web Servers	1	

Figure 10 — nginx findings grouped: the Medium CVE and an Informational server-detection entry.

The single Low severity finding was an ICMP Timestamp Request Remote Date Disclosure. The host responds to ICMP timestamp requests, which could allow an unauthenticated remote attacker to determine the system clock, potentially assisting in defeating time-based authentication protocols. This is a minor information-disclosure issue with low real-world exploitability.

Figure 11 — ICMP Timestamp Request Remote Date Disclosure detail, as reported by Nessus.

The remaining 13 findings were classified as Informational by Nessus and consisted of reconnaissance/fingerprinting data (OS identification, CPE, FQDN, hostname/IP consistency check, scan metadata) rather than exploitable vulnerabilities.

7. Phase 4: Exploitation & Verification

The Metasploit Framework was used to independently confirm findings outside of the Nessus scan, and — critically — to verify remediation after the fix was applied, rather than relying solely on the target's own reported state.

An auxiliary HTTP version scan against the target initially returned nginx/1.27.5, independently corroborating the vulnerable version identified by Nessus and Nmap. Attempts to remediate this on the host were first mis-applied — the nginx upgrade was initially (and mistakenly) run against the Kali attacking host rather than the target itself, which the Metasploit re-scan correctly caught, since it still reported the vulnerable version against the real target.

Root-cause investigation on the target instance found that nginx was not installed via the host's package manager at all, but was running as a Docker container (nginx:1.27-alpine) as part of a Docker Compose stack alongside the Django/Gunicorn application, PostgreSQL, and Redis containers, defined in docker-compose.prod.yml. The fix was applied by updating the pinned image tag to nginx:1.28-alpine and

recreating the container:

```
docker compose -f docker-compose.yml -f docker-compose.prod.yml pull nginx
docker compose -f docker-compose.yml -f docker-compose.prod.yml up -d --force-recreate nginx
```

Following the fix, the Metasploit HTTP version scan was re-run against the live target (18.170.42.8) and confirmed the running version had changed to nginx/1.28.3 — above the patched threshold for CVE-2026-1642. This provided independent, external confirmation of remediation, rather than relying only on the container logs.

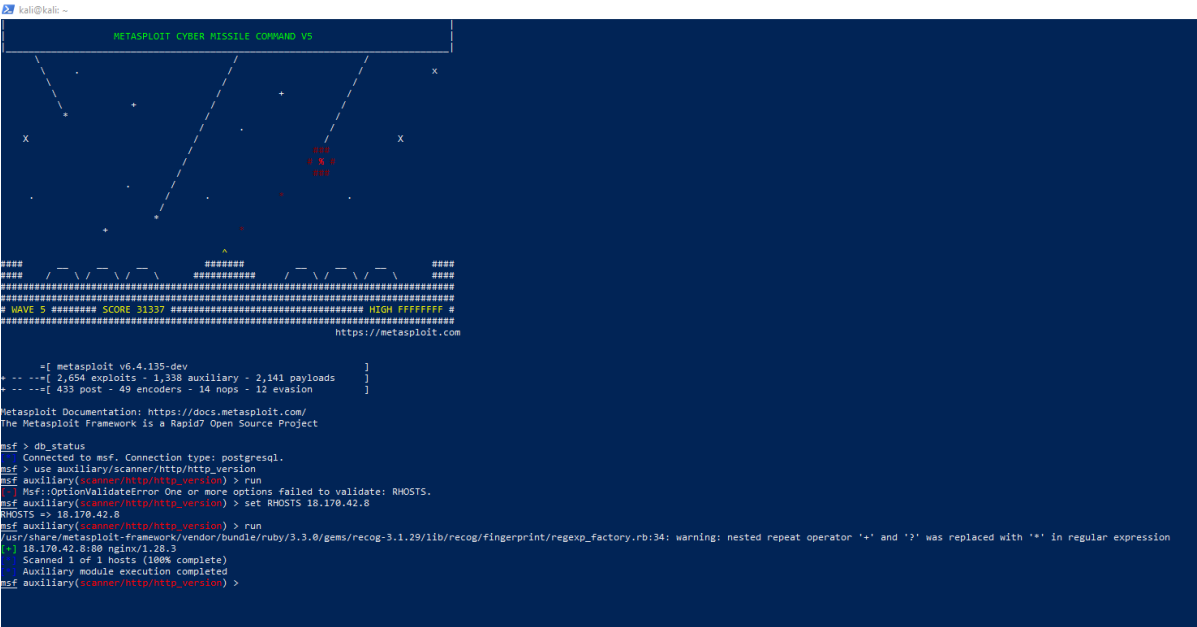


Figure 12 — Metasploit auxiliary/scanner/http/http_version module confirming the patched nginx/1.28.3 after remediation.

8. Summary of Findings

Finding	Severity	Status
Outdated nginx — SSL Upstream Injection (CVE-2026-1642)	Medium	Fixed
ICMP Timestamp Request Remote Date Disclosure	Low	Accepted (not fixed)
Missing security headers (CSP, HSTS, Permissions-Policy, X-Content-Type-Options)	Info	Open
Site served over plain HTTP (no TLS/HTTPS)	Info *	Open
robots.txt / sitemap.xml disclose site structure	Info	Open
Host OS (Ubuntu 24.04) — 64 pending package updates, 61 security	Info	Open

* The absence of HTTPS is not scored as a CVE-based finding by the scanning tools used, but is flagged here as a significant practical exposure — all traffic, including any future login/session cookies, currently travels unencrypted.

9. Remediation Actions & Recommendations

9.1 Remediated during this engagement

- nginx upgraded from 1.27.5 to 1.28.3 (Docker image nginx:1.27-alpine changed to nginx:1.28-alpine), resolving CVE-2026-1642. Verified externally via Metasploit post-fix.

9.2 Outstanding recommendations

- Enable HTTPS/TLS for the application (e.g. via a certificate on the nginx reverse proxy) — currently the site is served over plain HTTP only, which exposes all traffic, including any future authenticated sessions, to interception.
- Add the missing security headers identified by Nikto: Content-Security-Policy, Strict-Transport-Security (once HTTPS is enabled), Permissions-Policy, and X-Content-Type-Options.
- Apply the 64 pending host-level Ubuntu package updates (61 of which are security updates) on the football-hub-test instance.
- Consider disabling ICMP timestamp responses to close the Low-severity information disclosure finding.
- Restrict or review contents of robots.txt / sitemap.xml if any listed paths are not intended to be publicly enumerable.
- Ensure a working SSH key pair is retained and securely stored for the football-hub-test instance going forward; access during this engagement briefly required AWS EC2 Instance Connect after the original key pair could not be located.

10. Conclusion

The Football Hub Django application demonstrated a solid baseline security posture at the time of testing, with no Critical or High severity vulnerabilities identified across reconnaissance, enumeration, and vulnerability scanning. The single Medium severity finding (CVE-2026-1642, outdated nginx) was successfully remediated and independently re-verified within the engagement, demonstrating an effective and complete vulnerability management cycle from detection through to confirmed resolution. Addressing the outstanding recommendations in Section 9.2 — particularly enabling HTTPS and applying host-level security updates — would further strengthen the application's security posture.